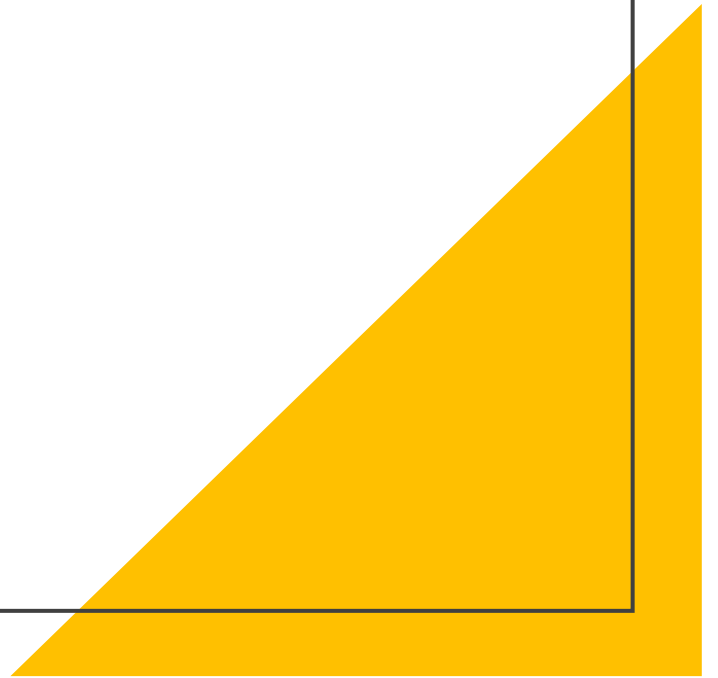


# Sociotechnical Security

CS 8803/4803

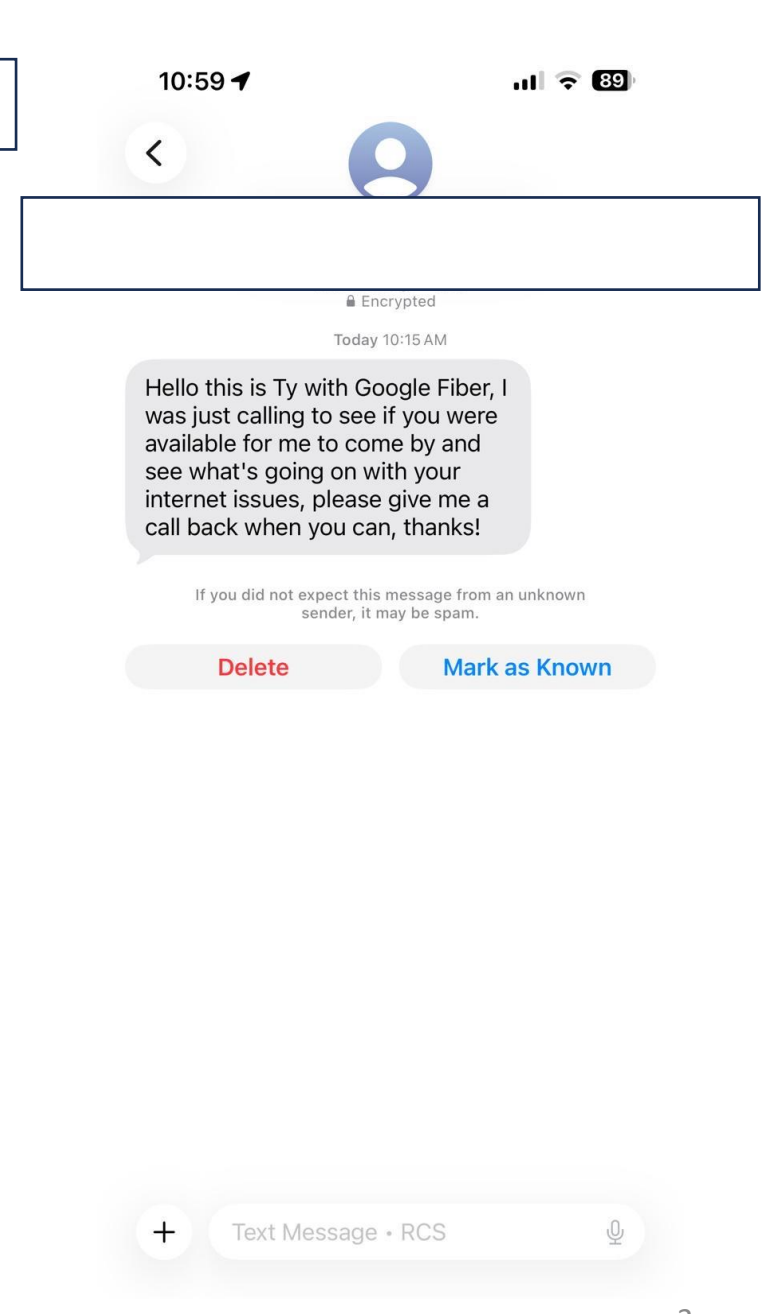
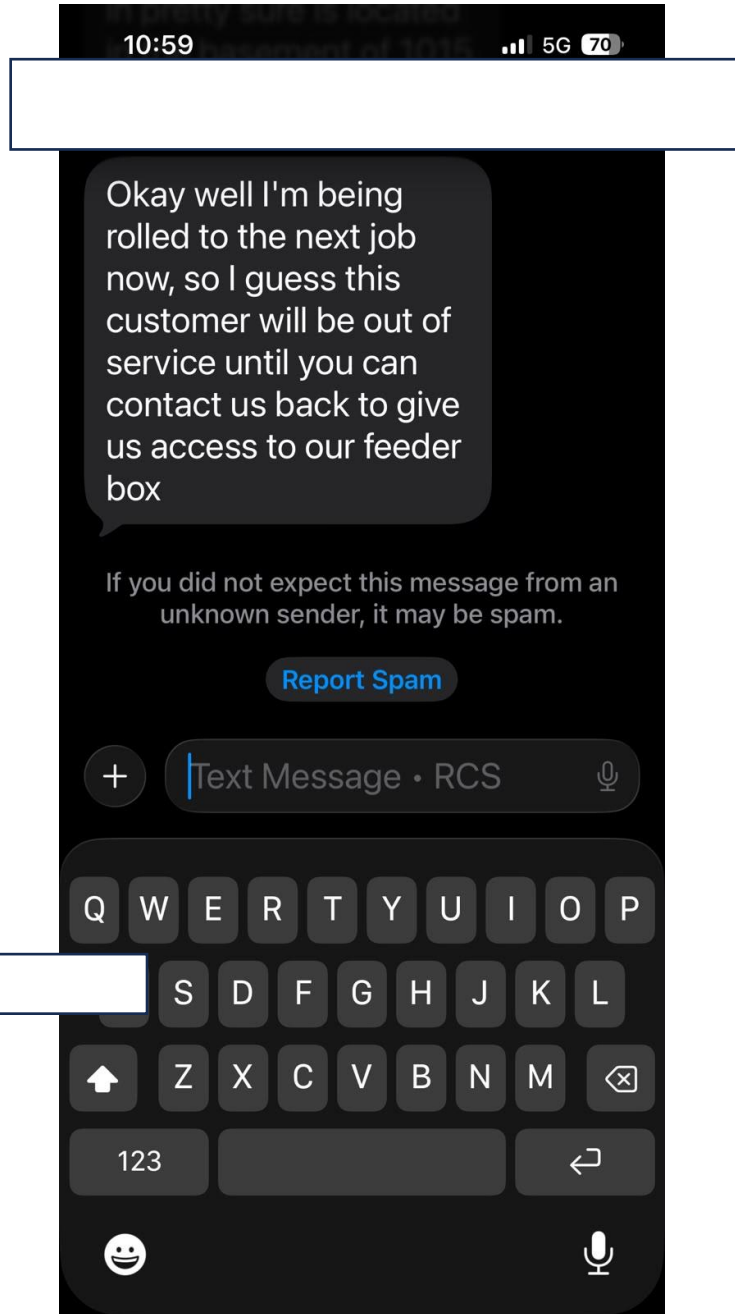
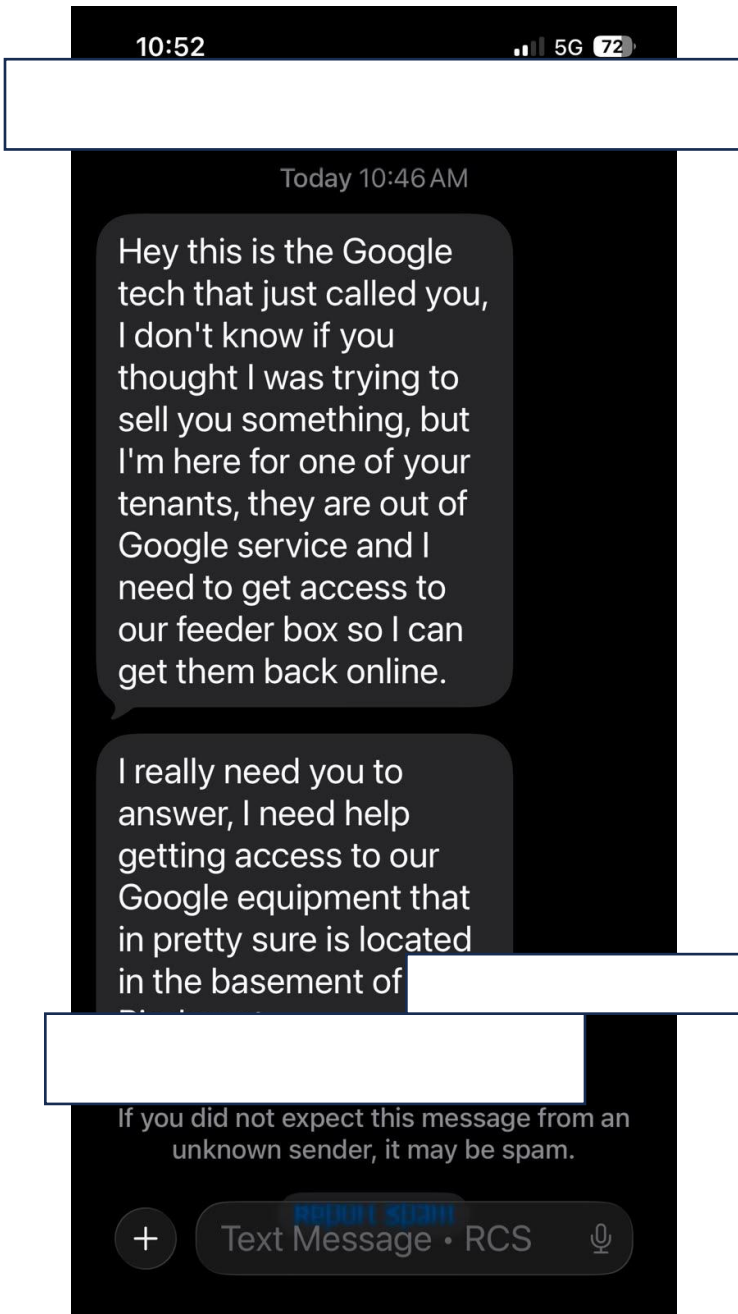
Professor Veronica Rivera

Lecture 8 – Security Warning Design I



# Last time

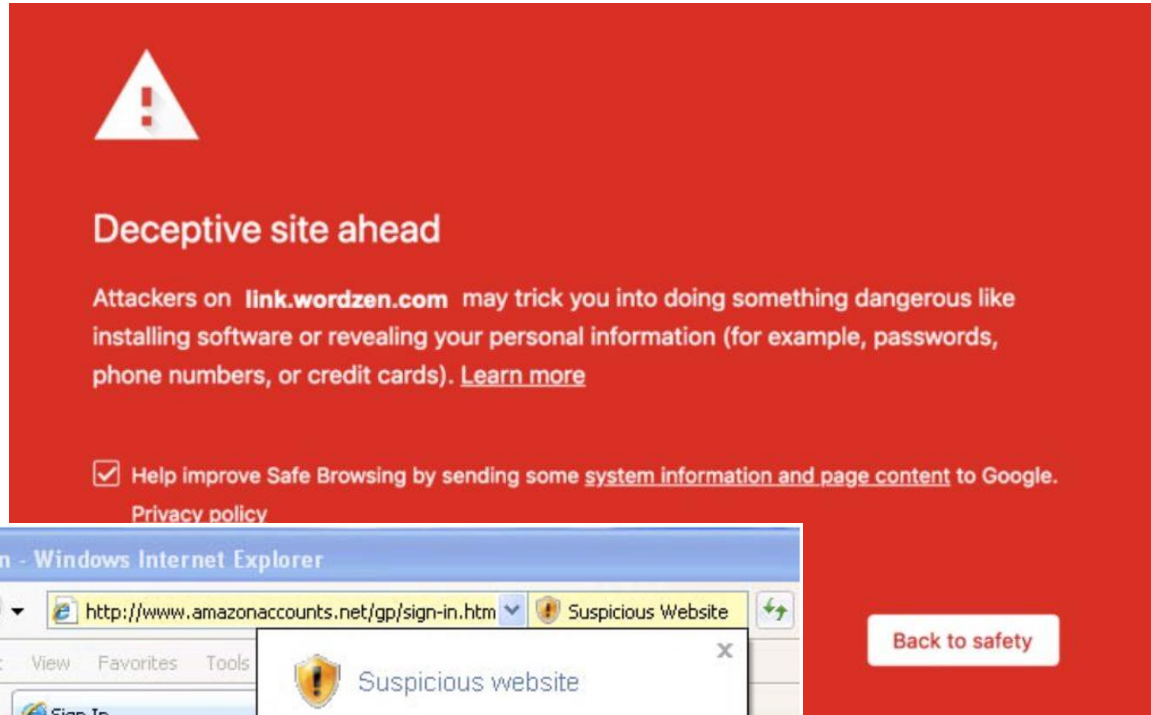
- Different types of phishing
- Phishing solution approaches
  - Security warnings
  - User education
  - Reporting phishing back to website
- How AI is changing economics of phishing



# Today

- Security warnings
  - Problems that warnings aim to solve
  - Lessons from decades of warning research
  - Limitations of warnings
- Discussion of early research on warnings led by Jedsada
- Wednesday:
  - Specific design problems for warnings
  - Warnings in other contexts (e.g., social media, LLMs, etc)

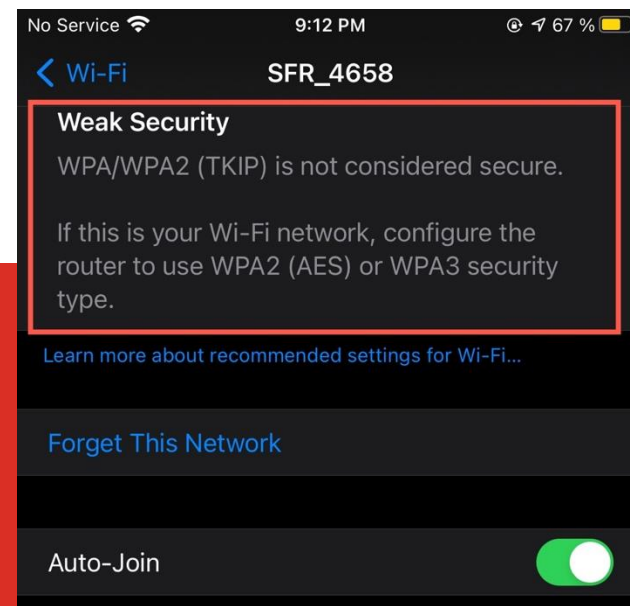
# Warnings



A red warning banner with a white exclamation mark icon. The text reads: "Deceptive site ahead". Below this, it says: "Attackers on **link.wordzen.com** may trick you into doing something dangerous like installing software or revealing your personal information (for example, passwords, phone numbers, or credit cards). [Learn more](#)". At the bottom, there is a checkbox that is checked, with the text: "Help improve Safe Browsing by sending some system information and page content to Google." and a link to "Privacy policy". A "Back to safety" button is located at the bottom right of the banner.



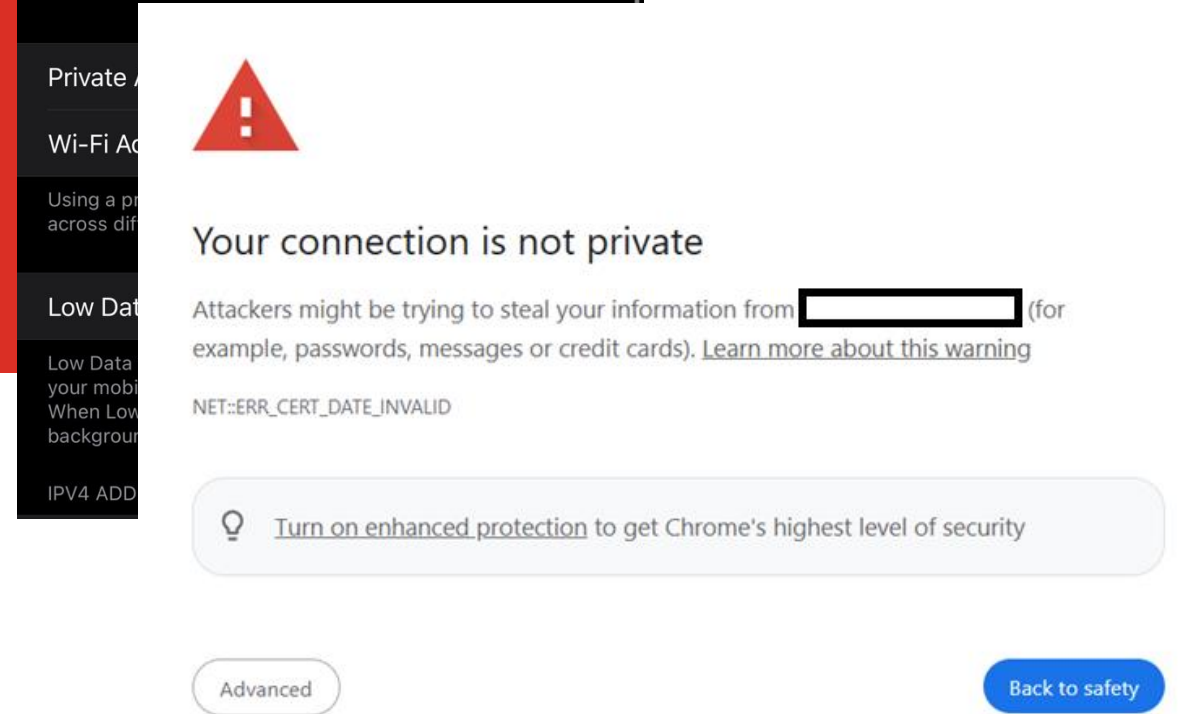
A screenshot of a Windows Internet Explorer browser window. The address bar shows "http://www.amazonaccounts.net/gp/sign-in.htm" with a "Suspicious Website" warning icon. A pop-up window titled "Suspicious website" is displayed, containing the following text: "This might be a phishing website.", "Phishing websites impersonate trustworthy websites for the purpose of obtaining your personal or financial information.", "Microsoft recommends that you do not give any of your information to such websites.", and "Report whether or not this is a phishing website." At the bottom of the pop-up is a link "What is Phishing Filter?". The background shows the Amazon.com sign-in page.



A screenshot of an iPhone's Wi-Fi settings page. The network "SFR\_4658" is selected. A red box highlights a "Weak Security" warning: "WPA/WPA2 (TKIP) is not considered secure. If this is your Wi-Fi network, configure the router to use WPA2 (AES) or WPA3 security type." Below the warning is a link: "Learn more about recommended settings for Wi-Fi...". Other options visible include "Forget This Network" and "Auto-Join" (which is turned on).



A screenshot of a browser's address bar showing a green padlock icon and the text "https://www.". To the left of the address bar are navigation icons (back, forward, refresh).



A screenshot of a Chrome browser warning page. It features a large red exclamation mark icon and the title "Your connection is not private". The text explains: "Attackers might be trying to steal your information from [redacted] (for example, passwords, messages or credit cards). [Learn more about this warning](#)". Below this, it shows the error code "NET::ERR\_CERT\_DATE\_INVALID". A light blue box contains the text: "Turn on enhanced protection to get Chrome's highest level of security". At the bottom, there are two buttons: "Advanced" and "Back to safety".

# Users fail to heed warnings

How can we get users to pay attention?

How can we make warnings better at keeping users secure?

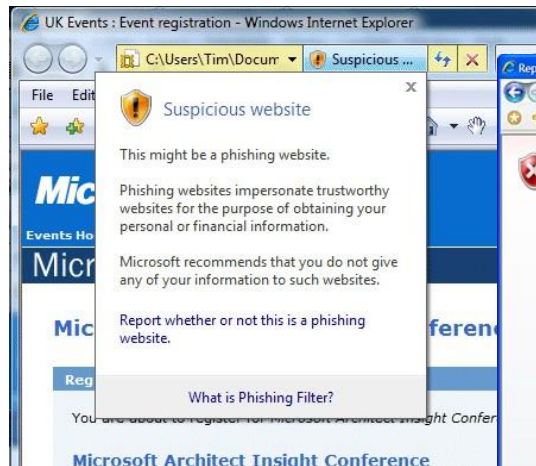
# Three lessons from warning research

1. Passive and active warnings play different roles
2. Warnings need to be usable
3. Warning utility is contextual

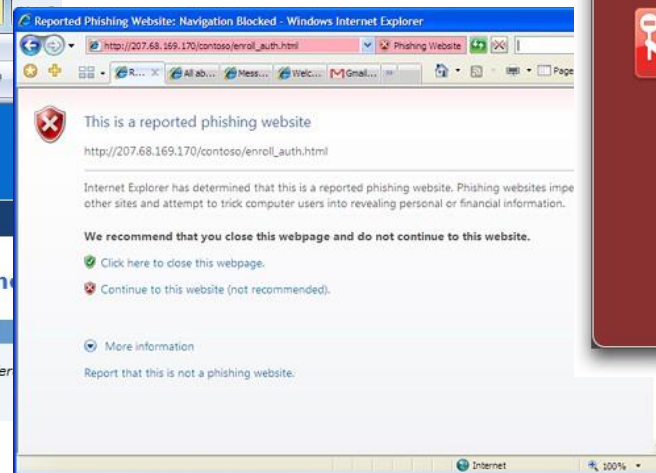


# Active vs. Passive Warnings (2008)

- Active warnings significantly more effective
  - Passive (IE): 100% clicked, 90% phished
  - Active (IE): 95% clicked, 45% phished
  - Active (Firefox): 100% clicked, 0% phished



Passive (IE)



Active (IE)



Active (Firefox)

# Active & passive warnings play different roles

Active warnings are the right choice when the danger is real and the system is confident.

However, sometimes passive warnings may be the right choice:

- Uncertain signals that produce false alarms
- Interruption has a cost
- Stakes are low

We should expect that most users will not see passive warnings

# Active Warnings

- **Known** phishing and malware sites
- **Broken** connection security
- Requests for access to **sensitive** data
- Unknown or **dangerous** downloads



## Your connection is not private

Attackers might be trying to steal your information from [redacted] (for example, passwords, messages or credit cards). [Learn more about this warning](#)

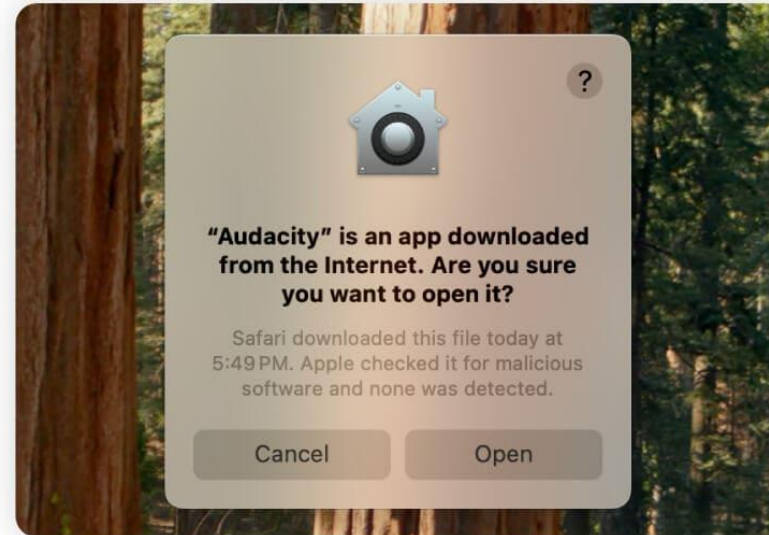
NET::ERR\_CERT\_DATE\_INVALID



[Turn on enhanced protection](#) to get Chrome's highest level of security

Advanced

Back to safety



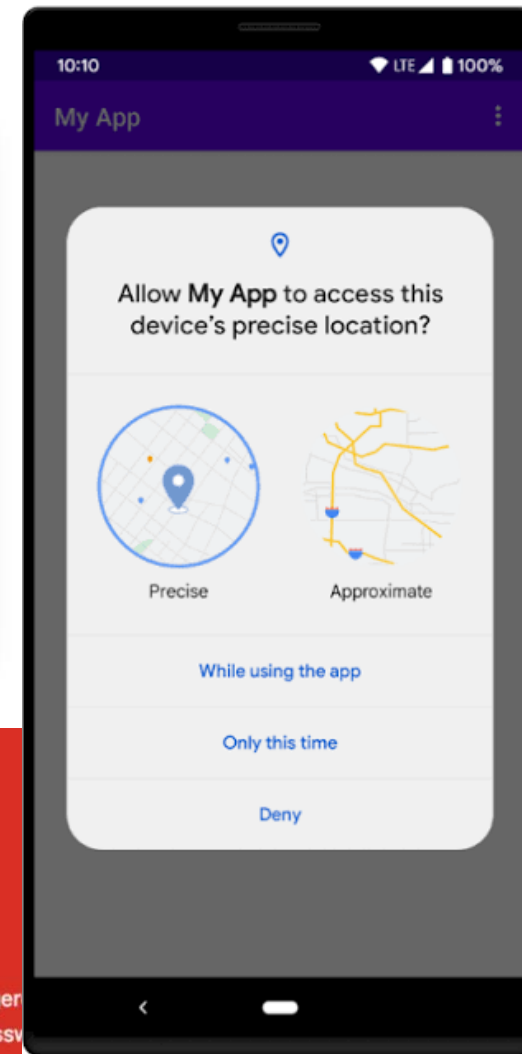
## Deceptive site ahead

Attackers on **link.wordzen.com** may trick you into doing something dangerous, like installing software or revealing your personal information (for example, passwords, phone numbers, or credit cards). [Learn more](#)

☒ Help improve Safe Browsing by sending some [system information and page content](#) to Google.  
[Privacy policy](#)

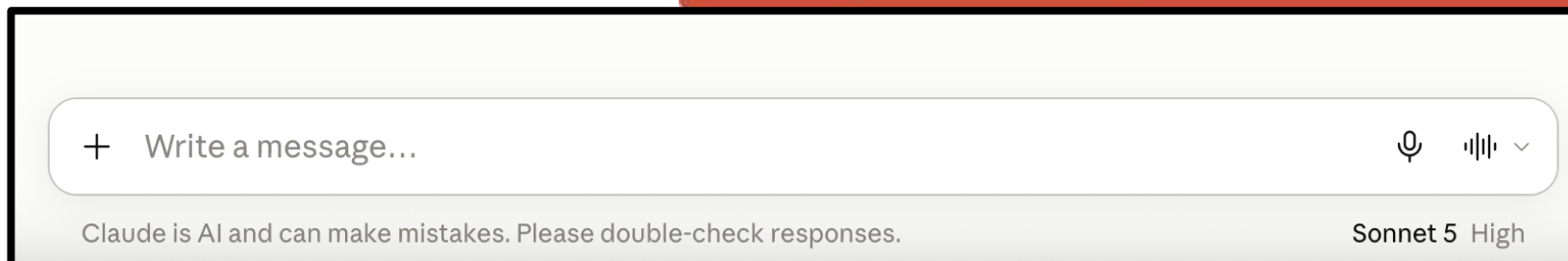
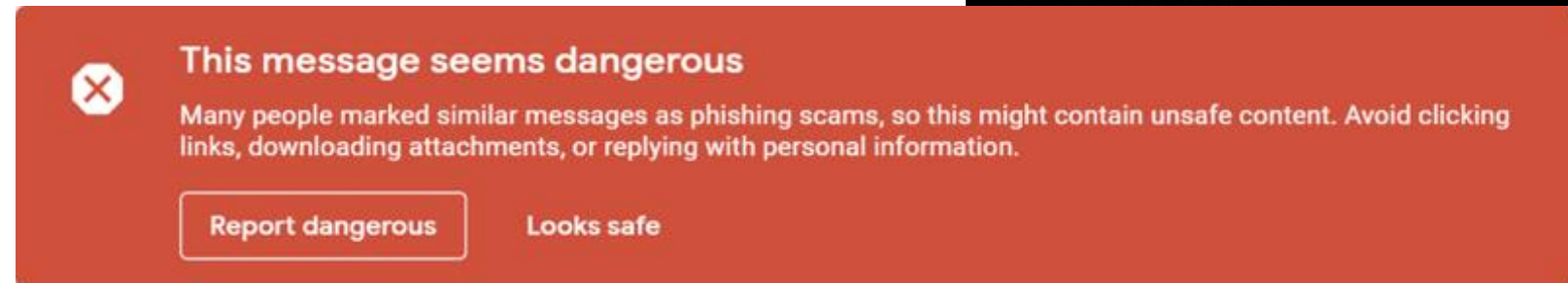
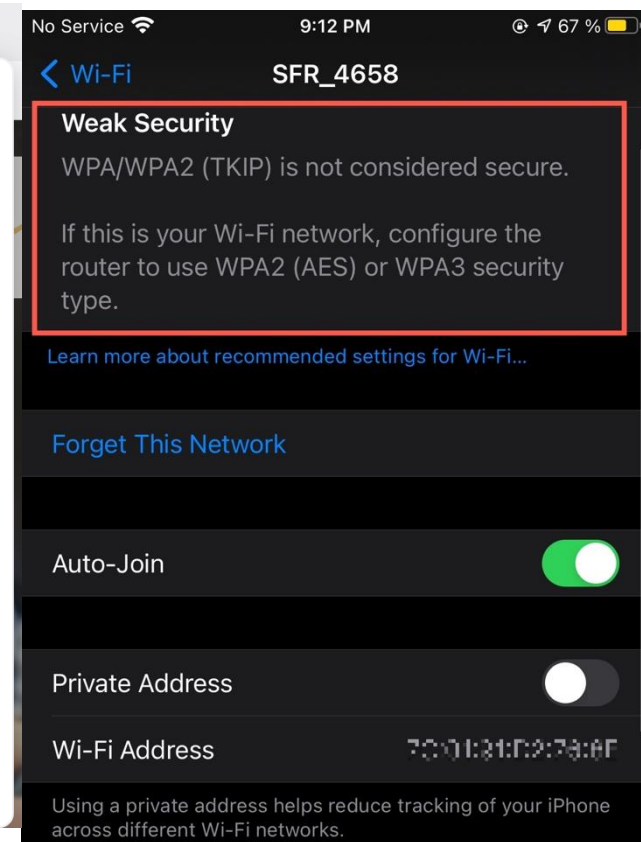
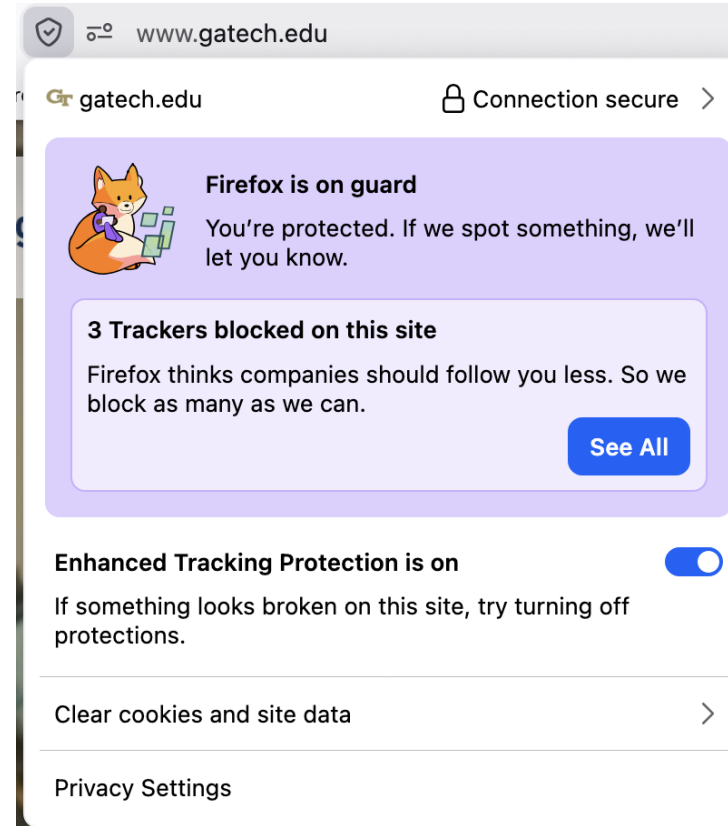
Details

Back to safety



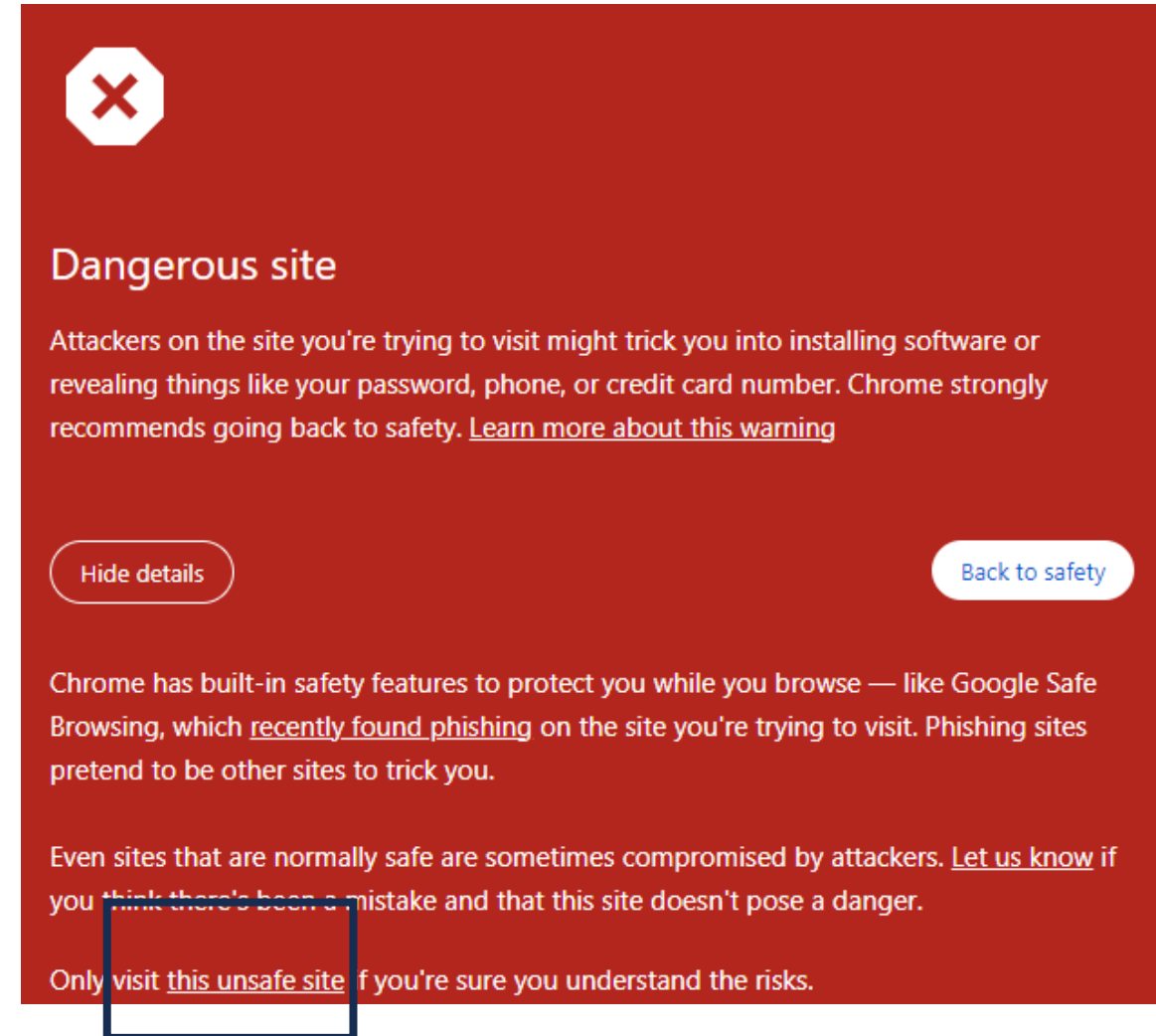
# Passive Warnings

- Suspicious emails
- Outdated wi-fi encryption
- HTTPS status
- AI reliability



# User agency in warnings

- A warning is an alternative to a prohibition
  - Underlying belief: software should not constrain users
- Active vs. passive warnings reveal different beliefs about agency
- Warnings: agency + guidance on making a choice
  - Usability concerns emerge



Ask yourself: Is your security or privacy UX:

**NECESSARY?**

Can you change the architecture to eliminate or defer this user decision?

**EXPLAINED?**

Does your UX present all the information the user needs to make this decision? **Have you followed SPRUCE? (see back)**

**ACTIONABLE?**

Have you determined a set of steps the user will realistically be able to take to make the decision correctly?

**TESTED?**

Have you checked that your UX is NEAT for all scenarios, both benign and malicious?



**NEAT**

When you involve the user in a NEAT security or privacy decision, explain the decision using these 6 elements:

**SOURCE:** State who or what is asking the user to make a decision

**PROCESS:** Give the user actionable steps to follow to make a good decision

**RISK:** Explain what bad thing could happen if the user makes the wrong decision

**UNIQUE KNOWLEDGE** user has: Tell the user what information they bring to the decision

**CHOICES:** List available options and clearly recommend one

**EVIDENCE:** Highlight information the user should factor in or exclude in making the decision



**SPRUCE**

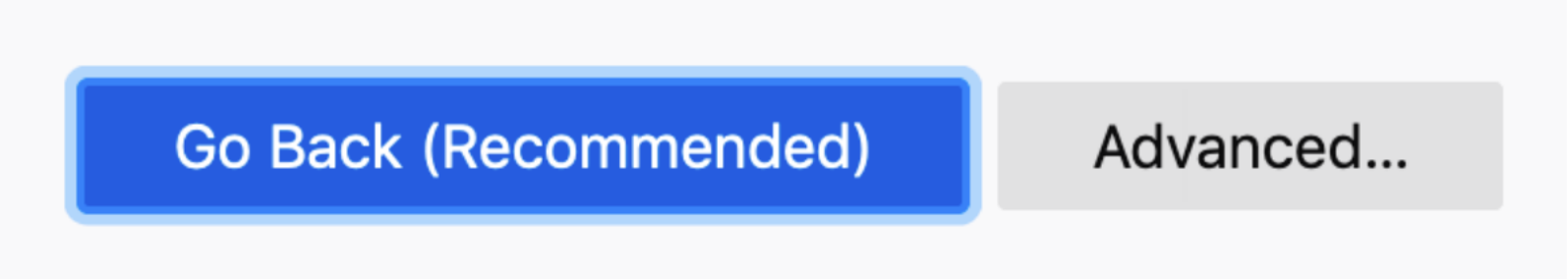
For more info, contact [neatux@microsoft.com](mailto:neatux@microsoft.com)

# Opinionated design: “correct” default

Can we nudge users to heed our advice?

**Opinionated design:** the use of visual design cues to promote a recommended course of action ([Felt et al., CHI 2015](#))

- Clear instruction
- Attractive preferred choice
- Unattractive other choice



Go Back (Recommended)

Advanced...

# Criteria for good warnings is contextual



Ask yourself: Is your security or privacy UX:

|                    |                                                                                                                            |
|--------------------|----------------------------------------------------------------------------------------------------------------------------|
| <b>NECESSARY?</b>  | Can you change the architecture to eliminate or defer this user decision?                                                  |
| <b>EXPLAINED?</b>  | Does your UX present all the information the user needs to make this decision? <b>Have you followed SPRUCE? (see back)</b> |
| <b>ACTIONABLE?</b> | Have you determined a set of steps the user will realistically be able to take to make the decision correctly?             |
| <b>TESTED?</b>     | Have you checked that your UX is NEAT for all scenarios, both benign and malicious?                                        |



**NEAT**

# Example: Early TLS

- TLS standardized in 1999
- Not many sites used it
- Q: how should TLS be communicated?
- A: passive lock indicator on sites using TLS



# Modern TLS

- Lets Encrypt founded in 2014
- Makes certificates fast and free
- Makes TLS universal
- Q: how should TLS be communicated?
  - Exact same question as before
- A: active warning when TLS fail
  - Different answer than before



**Be careful. Something doesn't look right.**

Firefox can't create a secure connection to the server at

Hide advanced

Go back (Recommended)

## Advanced

### What makes the site look dangerous?

It looks like this site is using old software with known security issues.

### What can you do about it?

Make sure you're using the latest version of Firefox. Go to Help > About Firefox in the menu. If you're using the latest Firefox, the problem is most likely with the site itself.

[Learn more about secure connection failures](#)

Error Code: SSL\_ERROR\_NO\_CYPHER\_OVERLAP

# Limitations of warnings

Fundamentally: warnings are information for a decision

## Limitations:

- Can't communicate that much information
- Many security problems can't be solved by in-the-moment user decisions
- Users' attention is limited

# For next time:

Wednesday we'll discuss specific design problems for warnings

- Salah is leading discussion

Make sure to sign up for a meeting time with Veronica this week

- This will be part of your project proposal grade
- Come with a specific list of concerns/questions

Schedule changes:

- Next Wednesday 9/30: No readings, come prepared to give each other feedback on projects
- Midpoint report: Now due 10/19 (instead of 10/14)
  - Veronica traveling this day
  - Fewer readings assigned for this day